Policy 10 – Authentication & Password

1. Table of Contents

1 Document Content Page

2 Policy Objectives and Scope

2.1 Purpose

2.2 Scope

2.3 Password Requirements

2.4 Multi-Factor Authentication (MFA)

2.5 Credential Storage & Transmission

2.6 Account Lockout & Recovery

3 Policy Compliance

3.1 Compliance Measurement

3.2 Exceptions

3.3 Non-Compliance

3.4 Continual Improvement

2. Policy Objectives and Scope

2.1 Purpose – Provide strong, user-friendly authentication that resists brute-force and credential-stuffing attacks.

2.2 Scope – All human and service accounts accessing organisational applications, devices, and infrastructure.

2.3 Password Requirements

- Minimum 12 characters or passphrase; prohibit commonly breached strings.
- No forced periodic rotation unless compromise suspected.
- Unique password per system; store passwords in an approved password manager.

2.4 Multi-Factor Authentication (MFA)

- Enforce MFA for admin accounts, remote access, and any system holding Confidential or Restricted data.

- Prefer authenticator apps or hardware tokens; SMS only as fallback.

2.5 Credential Storage & Transmission

- Hash user passwords with bcrypt/Argon2 (min 10 rounds) and per-user salt.
- Transmit login data only over TLS.
- Never embed secrets in code repositories.

2.6 Account Lockout & Recovery

- Lock accounts after 5 failed attempts within 15 minutes; auto-unlock after 30 minutes or admin reset.
- Identity-verify users before password reset; issue time-limited reset links.

3. Policy Compliance

3.1 Compliance Measurement – Automated scans ensure MFA enabled on 100 % target systems; random password audit shows compliance with length policy.

3.2 Exceptions – Systems lacking MFA require documented risk acceptance and compensating controls (e.g., IP-allowlist).

3.3 Non-Compliance – Weak or reused passwords, or disabled MFA, trigger immediate password reset and user retraining.

3.4 Continual Improvement – Review emerging passwordless options; adopt stronger methods when widely supported.